GROUP2 / REVIEW 1

P01
IT HELPDESK

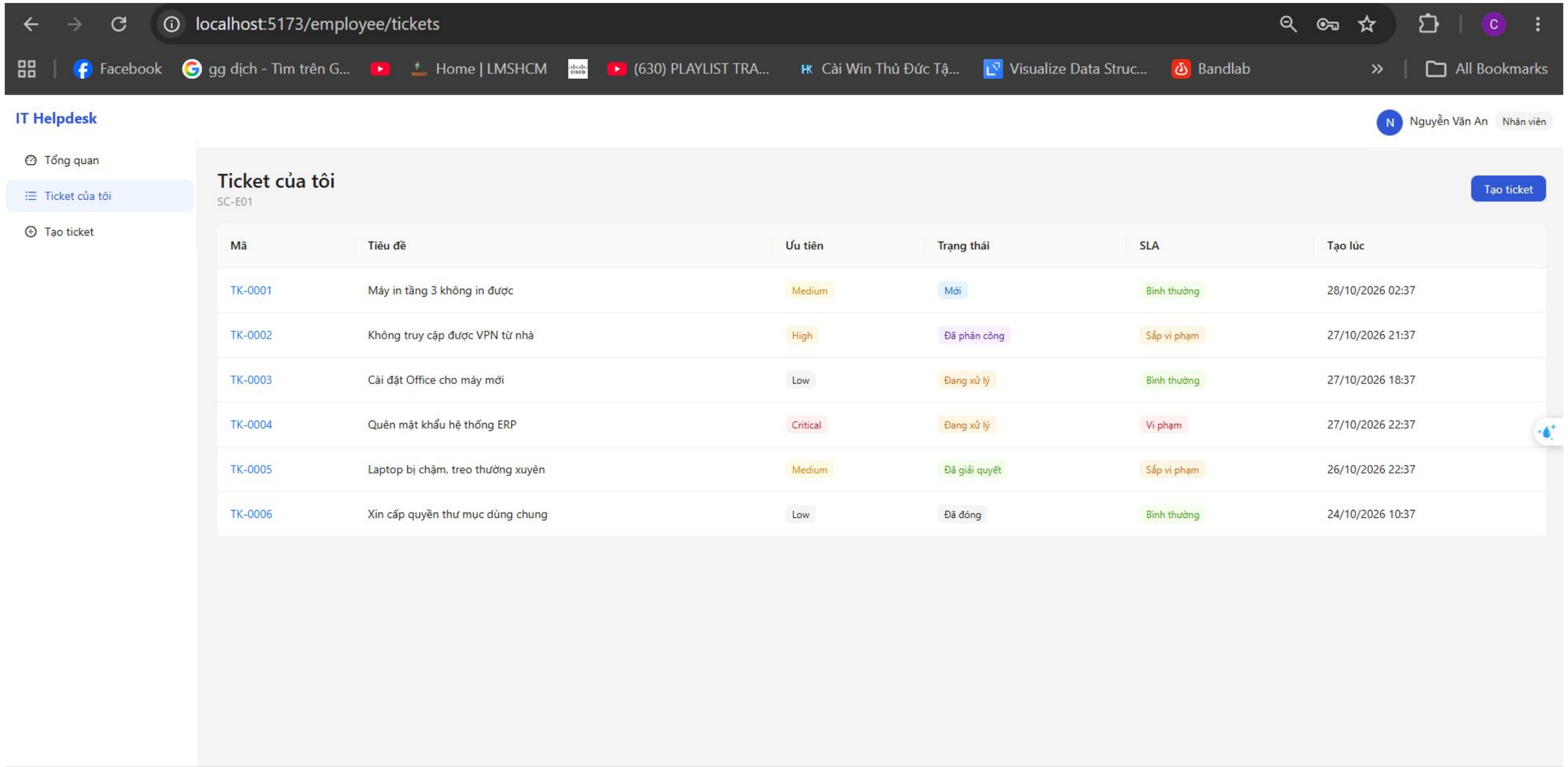
Kiểm soát truy cập
và giám sát bảo mật

Hồ sơ v1.2 Draft
30 tháng 10 năm 2026



Phiếu hỗ trợ của nhân viên

Báo lỗi, theo dõi người xử lý và hạn giải quyết trên cùng một hệ thống



FE skeleton đã vào main qua PR #2. Ảnh giao diện chưa chứng minh Backend hoặc quyền truy cập đã được nghiệm thu.

Phạm vi MVP và vai trò

HD01–HD14

Tài khoản và phân quyền
Ticket, tệp và trao đổi
Phân công và lịch sử xử lý
SLA, tìm kiếm và dashboard

Vai trò	Trách nhiệm chính
Employee	Tạo phiếu và xác nhận kết quả
IT Staff	Xử lý phiếu được giao
IT Manager	Điều phối, SLA và duyệt mở lại
Admin	Tài khoản, cấu hình và tra cứu

HD15 đánh giá hài lòng: Should, ngoài tiêu chí bắt buộc của MVP.

Ngoài phạm vi: sửa máy từ xa tự động, agent endpoint, Active Directory và SOC ngoài lab.

Quy trình xử lý ticket

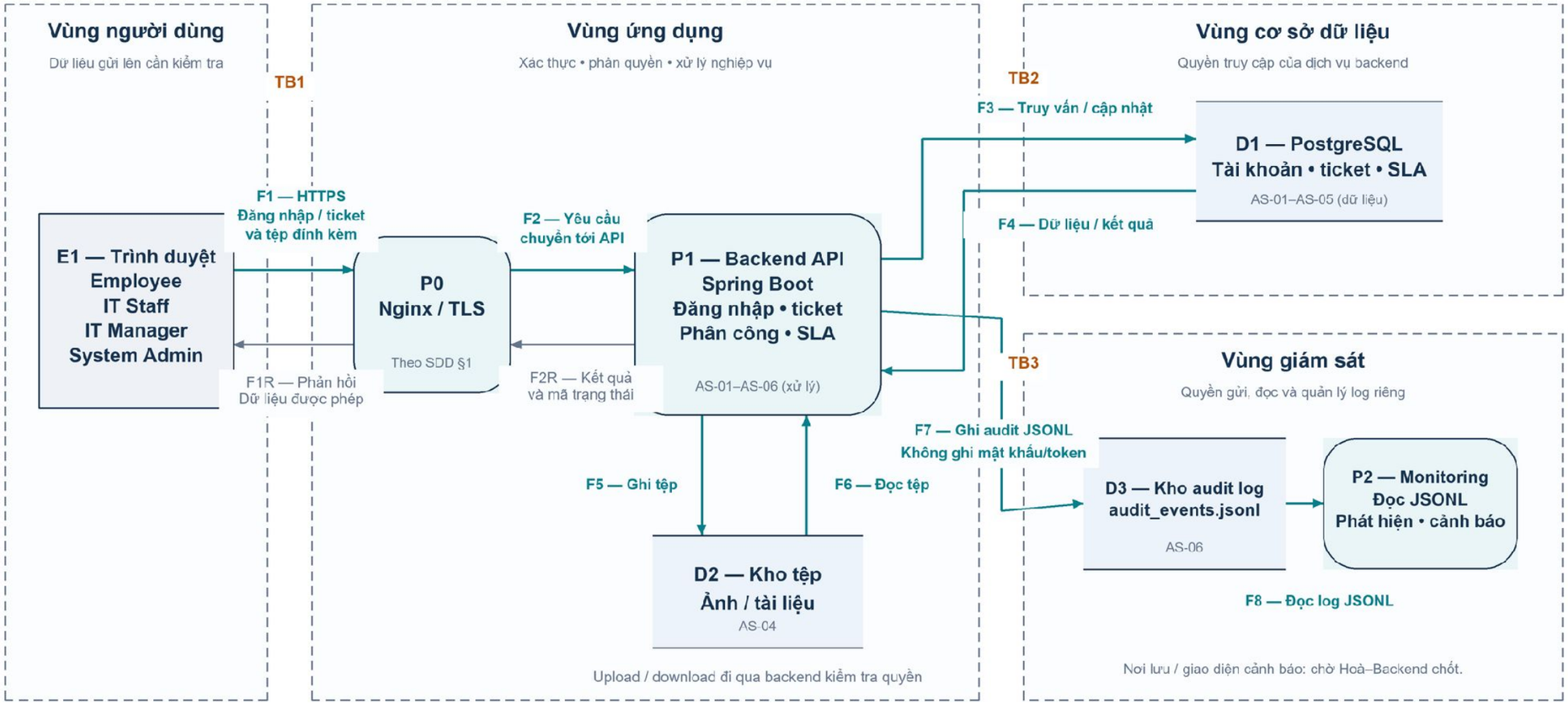
Giai đoạn	Người thực hiện	Kết quả
Tiếp nhận	Employee tạo phiếu Manager phân công	New, sau đó Assigned
Xử lý	Staff tiếp nhận và sửa lỗi Ghi giải pháp ít nhất 20 ký tự	In Progress, sau đó Resolved
Xác nhận	Chủ phiếu hoặc Manager đóng Employee yêu cầu mở lại khi chưa ổn	Closed hoặc request chờ duyệt

Mở lại từ Resolved trong 7 ngày, kèm lý do và qua Manager xét duyệt

Closed là trạng thái cuối. Nhánh Reopen/SLA và ảnh flow cần nhóm đồng bộ trước baseline.

DFD Helpdesk — v0.2

Group2 | P01 | 29-10-2026 | Draft — đối chiếu thiết kế SDD



Cách đọc sơ đồ

E = tác nhân bên ngoài • P = tiến trình xử lý • D = kho dữ liệu • F = luồng dữ liệu

TB1 Trình duyệt ↔ ứng dụng: kiểm tra phiên, quyền và dữ liệu đầu vào; bảo vệ đường truyền.

TB2 Backend ↔ DB: tài khoản dịch vụ có quyền tối thiểu; trình duyệt không kết nối DB trực tiếp.

TB3 Backend → kho JSONL → Monitoring: tách quyền ghi/đọc; không sửa/xóa log qua ứng dụng.

Theo SDD §1/§7; chưa xác minh triển khai. Kho file, cơ chế tải và lưu cảnh báo chờ chốt. AS-07: cấu hình/secrets.

Ảnh DFD gốc, giữ nguyên tỷ lệ. Mô hình logic đang đối chiếu với triển khai.

Quyền truy cập theo vai trò

Thao tác	Employee	IT Staff	Manager	Admin
Xem ticket	Của mình	Được giao + New chỉ xem	Toàn bộ	Chỉ đọc
Tạo ticket	Có	Không	Không	Không
Phân công	Không	Không	Có	Không
Đổi trạng thái	Không	Ticket phụ trách	Không *	Không
Đóng phiếu	Của mình, Resolved	Không	Resolved	Không
Tải byte tệp	Trong quyền	Trong quyền	Trong quyền	Không *
User và role	Không	Không	Không	Có

*** Manager đổi status và Admin tải byte: còn chờ SE–Khánh chốt contract**

Đề xuất mã lỗi v1.2: 401 xác thực, 403 role endpoint, 404 phạm vi, 403 thao tác, 422 trạng thái.

Màn hình chi tiết và validation

SDD §5 đã có 9 Screen ID, screen flow và wireframe



Ảnh wireframe là bản thiết kế. Nhãn Login cần Email và nhánh Reopen cần khớp Resolved theo SRS.

STRIDE và các tài sản cần bảo vệ

Nhóm rủi ro	Threat ID	Kiểm soát chính
Tài khoản và phiên	TH-01, TH-08	Xác thực, giới hạn login, thu hồi token
Quyền ticket và role	TH-02, TH-04, TH-07	Kiểm role và quyền đối tượng
Tệp đính kèm	TH-05, TH-06	Loại, kích thước, số lượng và quyền tải
Audit và bảo vệ log	TH-03, TH-09	Ghi nhận hành động, quyền ghi/đọc
Thông tin bí mật	TH-10	Biến môi trường, rà báo cáo secrets
Đầu vào XSS/SQLi	TH-11, TH-12	Validation, encode và truy vấn tham số

12 TH **7 mã SR** **8 nhóm test**

Risk sơ bộ dùng Impact × Likelihood. Rủi ro còn lại chưa có đánh giá sau kiểm chứng.

Kế hoạch kiểm thử và minh chứng

Hạng mục	Bằng chứng hiện có	Trạng thái cần trình bày
Ứng dụng: 8 nhóm SEC-TC	Kế hoạch tại SecRS §6 EV-HD-21…28 được tổ chức theo nhóm	Chưa có kết quả kiểm thử tích hợp
IA-HD03: upload/download	PR #5 có test plan và EV-HD-23	NOT RUN, chờ Backend và contract
IA-HD07: hardening	PR #5 có EV-HD-28 summary	Partially Verified, thiếu log gốc
Khởi tạo DB trong lab riêng	PR #5 báo cáo schema/seed PostgreSQL 16	Báo cáo PASS cho DB, chưa là PASS bảo mật

Giới hạn bằng chứng

Cần đúng commit, môi trường và kết quả từng ca. Báo cáo một phần chưa đủ để nghiệm thu toàn bộ IA-HD07.

Triển khai và phần còn chờ tích hợp

Mạng trong Compose PR #6	Thành phần theo cấu hình
p01-public	Gateway Nginx
p01-front	Gateway và Frontend
p01-back	Gateway và Backend
p01-db	Backend và PostgreSQL

Thiết kế 443 public, DB 5432 nội bộ. Môi trường lab Nginx của PR #5 được ghi riêng.

Đã có bản nộp

Compose, Dockerfile và SQL
Ảnh chạy Frontend và DB
Biến môi trường bắt buộc

Còn chờ

Mã Backend, gateway và TLS
Monitoring, log/backup
Đối chiếu lab của Nhi với commit mới

Tiến độ và phối hợp tuần 2

Thành viên	Đầu ra hiện có	Việc tiếp theo
Khiêm	Bộ hồ sơ, DFD và slide v1.2 PR #3 Draft	Tổng hợp quyết định và dẫn Review 1
Khánh	Access Matrix, PR #4 đã gộp	Chốt quyền và thứ tự mã lỗi với SE
Hoà	Catalog/schema/rules mức thiết kế	Chốt công cụ, ngưỡng và log với Backend
Nhi	PR #5 lab, báo cáo một phần	Bổ sung log gốc, Gitleaks và deployment
Trí / Cường	SRS, kiến trúc, ERD/API/AuthN	Chốt Reopen/SLA/contract và Backend
Chính	FE PR #2 đã gộp, SDD §5, PR #6	Sửa ảnh flow/Login và hoàn thiện tích hợp

T2-01 giữ In progress. T2-08 giữ Review. Phê duyệt phạm vi của GV vẫn chờ ghi nhận.

Quyết định cần ghi tại Review 1

Điểm	Nội dung cần xác nhận	Phối hợp
PC-01	Cách tải tệp, thời hạn và thu hồi URL	Nhi, Cường/Trí, Khánh
PC-02	Reopen, SLA và ảnh flow đúng trạng thái	Trí, Cường, Khánh, Chính
PC-03	Quyền, mã lỗi và validation dữ liệu	Khánh, Cường/Trí
PC-04	Log, rule, công cụ và retention	Hoà, Backend, Nhi
PC-05	Triển khai, TLS, network và bằng chứng	Nhi, Chính, Trí
PC-06	Review mã NFR và tham chiếu bản gộp	Chính, Cường/Trí

Giảng viên góp ý và xác nhận phạm vi MVP

Khiêm ghi quyết định thực tế, người phụ trách, hạn và link bằng chứng vào file 08. Chuyển Done khi đủ đầu ra và xác nhận.